



400-650-7088

TongWeb V7.0

等级保护指南

版本：7049_M9A01

2025 年 09 月

声明

版权

Copyright ©2025北京东方通科技股份有限公司或其关联公司（以下简称“东方通”）。保留所有权利。

版权声明

- 本文档的所有权和知识产权归属于东方通所有。
- 除非另有明确约定，东方通不授予任何明示或暗示的许可或权利，使用者不得以任何方式将本文档中的任何内容用于商业目的。
- 东方通对本文档享有版权。本文档的所有内容，包括但不限于文字、图像、图表、图标、示意图、屏幕截图等，均受版权法和国际版权条约的保护。
- 未经东方通明确授权，任何人不得对本文档以任何形式复制、修改、传播、分发、展示或进行衍生创作。

商标声明

- **东方通**、**TongTech**标识以及其他相关东方通图形、徽标、服务名称和商标（以下统称为“东方通商标”）是东方通或其关联公司的注册商标或商标。
- 未经东方通明确授权，任何人不得以任何方式使用、复制或展示东方通商标。此外，未经东方通事先书面同意，不得将东方通商标与其他商标、标识或徽标进行混淆、链接或结合使用。
- 除非另有明确约定，本商标声明不授予任何明示或暗示的许可或权利，对东方通商标的使用须获得东方通的明确授权。
- 本文档提及的所有其他商标、标识、徽标或产品名称均为其各自所有者的财产，并可能受其各自的商标法保护。

免责声明

请在使用东方通产品之前仔细阅读本免责声明，并根据自身情况判断是否继续使用。如有任何问题，请联系我们的客户支持团队。

- 本产品的使用是基于用户自己的判断和风险评估。本文档仅作为使用指导，不对使用本产品所产生的结果做任何明示或暗示的担保。
- 东方通不对用户未按照本文档中的指导正确使用东方通产品而导致的任何损失或损害承担责任；
- 本文档可能会包含第三方提供的内容、链接或资源，这些内容由第三方自行负责。东方通对于这些内容的准确性、完整性、合法性或可靠性不承担责任。用户在使用这些内容时应自行判断和承担风险。
- 由于产品版本升级或其他原因，本文档内容会不定期更新。东方通保留在不事先通知用户的情况下随时对文档进行修改、更新或中止的权利。

如需获取有关东方通产品的许可或使用权，请联系东方通或授权代理商。任何违反本声明的行为将受到适用法律的追究。

版本变更说明

本手册的更新是累积的。因此，最新的手册版本包含对以前版本所做的所有更改。

手册版本	适用于产品版本	更新内容
7049_M9A01	7.0.4.9_M9	修改如下章节： 4.1 用户管理，系统默认提供监视管理员，替换截图。
7049_M8A01	7.0.4.9_M8	无
7049_M7A01	7.0.4.9_M7	无
7049_M6A01	7.0.4.9_M6	无
7049_M5A01	7.0.4.9_M5	修改如下章节： 第2章 开启等保功能，新增“加密字符串时，必须在目标“\${TongWeb_HOME}/bin”目录中执行password脚本；否则，生成的加密字符串将会不一样，从而导致无法成功解密”说明。
7049_M4A01	7.0.4.9_M4	无
7049_M3A01	7.0.4.9_M3	无
7049_M2A01	7.0.4.9_M2	无
7049_M1A01	7.0.4.9_M1	无
7049A01	7.0.4.9	第5章 审计日志，替换审计日志被篡改的截图，界面新增操作IP列。
7048A01	7.0.4.8	第3章 创建用户，新增“修改密码时要求5次以内密码不能重复”的说明。
7047A01	7.0.4.7	无
7046A01	7.0.4.6	无
7045A01	7.0.4.5	“1.2 创建用户”更新“图 1.2-4：创建用户”、“图 1.2-5：编辑用户”。
7044A01	7.0.4.4	“1.2 创建用户”增加用户权限说明。
7043A01	7.0.4.3	无
7042A01	7.0.4.2	无
7041A01	7.0.4.1	● 按等保2.0需求提供新功能说明。 ● 将\${TW_HOME}改为\${TongWeb_HOME}。 ● “1.2 创建用户”更新“创建用户属性”中的密码属性说明。

前言

本文档是TongWeb产品的用户使用手册之一，详细提供等级保护功能开启后的使用说明。

适合的对象

本手册主要适用于生产环境中的系统管理员，部分内容同样适用于应用开发人员和应用部署人员。

本手册假定您已经具备如下技能：

1. 基本系统管理任务；
2. 安装软件；
3. 使用Web浏览器；
4. 启动数据库服务器；
5. 在终端窗口中发布命令。

用户使用手册集

TongWeb为您提供的用户使用手册集包含的文档有：

- 000_TongWeb_V7.0用户手册导读：各版本手册集的目录及手册版本说明。
- 001_TongWeb_V7.0快速使用手册：提供各版本客户快速安装，应用部署，及常用配置的说明。
- 002_TongWeb_V7.0产品简介及安装指南：提供各版本各平台上的安装启动的步骤。
- 003_TongWeb_V7.0服务配置指南：提供Web容器、EJB容器、启动参数配置及各项基础服务的配置说明。
- 004_TongWeb_V7.0应用管理指南：提供管理控制台对应用进行部署和管理操作的说明。
- 005_TongWeb_V7.0工具使用指南：提供Eclipse、IDEA、Patch、TongAPM、appclient、pinpoint、web应用迁移等工具的使用说明。
- 006_TongWeb_V7.0Commandstool使用指南：提供命令行Commandstool的使用说明，基本参数及所有命令示例。
- 007_TongWeb_V7.0与Tivoli集成手册：对JSON整体结构及各监视项的说明。
- 008_TongWeb_V7.0二次开发接口：TongWeb的JMX、REST、SNMP接口说明。
- 009_TongWeb_V7.0应用开发手册：提供在TongWeb上开发应用的各类规范说明。
- 010_TongWeb_V7.0等级保护指南：提供等级保护功能开启后的使用说明。
- 100_TongWeb_V7.0集群管理指南：详细介绍集群的配置和管理。
- 200_TongWeb_V7.0用户使用手册-轻量级版：提供轻量级版本客户详细的服务配置及应用管理的说明。

技术支持

东方通产品将为您提供全方位的技术支持，您可以通过以下方式获得技术支持：

网址：www.tongtech.com

电话：400-650-7088

邮箱：support@tongtech.com

您在取得技术支持时，需提供如下信息：

1. 您的姓名
2. 您的公司信息
3. 您的联系方式
4. 操作系统及其版本
5. 产品版本号
6. 日志等错误的详细信息

目 录

第1章 等级保护	1
第2章 开启等保功能	2
第3章 创建用户	4
3.1 双因子认证	7
3.2 账号过期	8
第4章 用户标识	10
4.1 用户管理	10
4.2 用户标识	11
第5章 审计日志	13
附录A 术语及缩略语	14

第1章 等级保护

2017年,《中华人民共和国网络安全法》的正式实施,标志着等级保护2.0的正式启动。随着信息技术的发展,等级保护对象已经从狭义的信息系统,扩展到网络基础设施、云计算平台/系统、大数据平台/系统、物联网、工业控制系统、采用移动互联技术的系统等,基于新技术和新手段提出新的分等级的技术防护机制和完善的管理手段是等级保护2.0标准必须考虑的内容。

TongWeb为此提供了以下符合等保2.0的新功能。

第2章 开启等保功能

注意：安全保密管理员secadm、安全审计员audit，需在开启等保模式下，才能登录集中管理工具。

TongWeb首次安装后，需在未启动TongWeb之前做如下配置，开启等保2.0相关功能。

1. 在启动参数配置文件\${TongWeb_HOME}/bin/external.vmoptions以及
\${TongWeb_HOME}/domain_template/bin/external.vmoptions（开启TongWeb域等保）中增加以下参数。

```
#server_options
...
-DstrictSecurity=true
-DstrictSecurity.email.smtpHost=<smtp.exmail.xxx.com>
-DstrictSecurity.email.port=25
-DstrictSecurity.email.username=<user_email_adress>
-DstrictSecurity.email.password=<user_email_password>
```

说明：

- -DstrictSecurity：等保开关，true为打开
- -DstrictSecurity.email.smtpHost：账号找回时发送邮箱的smtpHost
- -DstrictSecurity.email.port：账号找回时发送邮箱的端口
- -DstrictSecurity.email.username：账号找回时发送邮箱的账号
- -DstrictSecurity.email.password：账号找回时发送邮箱的密码。填写的邮箱密码需要是密文。请填写为您邮箱密码的密文。

您可以通过如下方式，将您的邮箱密码加密。

使用“\${TongWeb_HOME}/bin/password.sh”，执行如下命令，可将密码明文转为密文。

```
sh password.sh abc123.com
```

注意：

如果需要获取某个字符串的加密字符串，必须在目标“\${TongWeb_HOME}/bin”目录中执行该脚本；否则，生成的加密字符串将会不一样，从而导致无法成功解密。

2. 也可以在管理控制台的**启动参数配置 > 服务器参数**中添加，如下图所示。

启动参数配置

启动参数配置 ⓘ

此页显示了服务器启动参数，包括JVM参数，服务器参数，环境变量JAVA_HOME等，可以执行修改删除和保存操作

jvm参数

其他jvm参数

服务器参数

环境变量

添加

删除

☐	-DstrictSecurity=true
☐	-DstrictSecurity.email.smtpHost=smtp.exmail.qq.com
☐	-DstrictSecurity.email.port=25
☐	-DstrictSecurity.email.username=tongweb@tongtech.com
☐	-DstrictSecurity.email.password=E/9WlafLpQFIH0pNgqglLQ==
保存 取消	

图 3.1-1：启动参数配置中添加等保参数

说明：

开启等保后，如果手动修改了tongweb.xml配置文件，重启后会认为tongweb.xml被篡改，TongWeb会自动使用备份的tongweb.xml文件。

3. 启动TongWeb。

说明： 以下功能同样适用于**集中管理工具**。

第3章 创建用户

系统管理员在默认系统安全域defaultRealm中可以创建用户、编辑用户、不能分配角色权限及删除用户。

默认的系统管理员用户名为**thanos**，初始密码为**thanos123.com**。首次登录前需要使用初始密码设置新的密码及邮箱后，使用系统管理员的账号及新密码登录管理控制台。

说明：开启等保2.0前创建的用户，在开启等保后维持原用户权限。

1. 展开管理控制台左侧导航树中的“**安全服务**”节点，单击“**安全域管理**”，进入安全服务的安全域管理页面，如下图所示。



图 3.1-1：安全服务页面

2. 单击“defaultRealm”后的“**管理用户**”（只有这个安全域是针对控制台的三员分立），进入“用户管理”页面，用户列表显示已创建的所有三员用户，如下图所示。列表字段包括用户名称、用户所属角色（系统管理员、安全保密管理员、安全审计员，若还未分配角色则显示为空）。



图 3.1-2：系统管理员默认安全域用户列表

提示：系统管理员 **rig** 登录集中管理工具 **http://<master_ip>:9060/heimdall/**，点击左侧导航栏“**用户管理**”进入用户列表页面，如下图所示。



图 3.1-3：集中管理控制台用户列表

3. 单击“创建用户”，系统管理员可输入用户名称、密码，进行加密方式、密码使用期限设置，如下图所示。

提示：系统管理员 **rig** 登录集中管理工具 **http://<master_ip>:9060/heimdall/**，点击左侧导航栏“用户管理”进入用户列表页面，点击“创建用户”后，同样如下图所示。

配置用户管理

配置用户管理

用户信息

返回

创建用户

用户名称

用户名称

密码加密摘要算法

☒ SM3

☐ MD5

☐ SHA-1

☐ SHA-256

☐ SHA-512

☐ DIGEST

☐ SM2

密码加密摘要算法

加强字节长度

8

将密码和一些随机数字混合加密，增加强度

迭代加密次数

3

迭代多次加密，增加强度

密码长度

10

密码长度限制

密码

密码

确认密码

确认密码

密码最短使用期限

0

天

密码可修改前最短使用期限，默认值0，表示立即生效

密码过期开关

☒ 开启

开启后，第一次登录和密码过期时需要修改密码

密码最长使用期限

90

天

密码过期时间，默认值90天

邮箱

邮箱

账号过期天数

账号过期天数，期间未登录账号将不可用

保存

取消

图 3.1-4：创建用户

创建用户属性：

- **用户名称：**新建用户的名称，必填。
- **密码加密摘要算法：**用户密码的加密方式，NONE 表示不加密。当 web.xml 中使用验证类型为 DIGEST 时，密码的加密方式应选择 DIGEST。
- **加强字节长度：**将密码和一些随机数字混合加密，增加强度。必须在 2-32 位。
- **迭代加密次数：**迭代多次加密，增加强度。必须在 2-32 次。
- **密码长度：**密码最小位数，必须在 10-32 位。

7049_M9A01

版权所有©东方通

5

- **密码：**用户对应的登录密码。必须由大写字母、小写字母、数字、特殊字符 4 种组成。
- **确认密码：**再次输入密码，以防止密码输入错误。（使用密文传输）
- **密码最短使用期限：**密码可修改前最短使用期限，默认值 0，表示可立即修改。必须在 0-90 天。
- **密码最长使用期限：**密码过期时间，必须在 0-90 天，必须大于最短使用期限。
- **邮箱：**用于账号找回时接收邮件。（使用匿名显示，密文传输）
- **账号过期天数：**账号每次登录后的有效天数，超过配置过期天数后，登录时会提示账号过期。

4. 系统管理员可对已创建的用户进行**编辑**，支持修改密码长度、密码、密码使用期限及邮箱（用户名由安全保密管理员修改），还可以开启双因子认证（参见“[双因子认证](#)”章节），修改完成后单击“**保存**”。如下图所示。

说明：

- 开启等保后，在集中管理控制台上defaultRealm安全域将被隐藏，无法创建或管理其中的用户。
- 修改密码时要求5次以内密码不能重复。

配置用户管理
配置用户管理 ⓘ

用户信息

返回

编辑用户

用户名称

thanos

密码加密摘要算法

☒ SM3
☐ MD5
☐ SHA-1
☐ SHA-256
☐ SHA-512
☐ DIGEST
☐ SM2

加强字节长度

8

迭代加密次数

3

密码长度

10

密码

.....

确认密码

.....

密码最短使用期限

0

密码过期开关

☒ 开启

密码最长使用期限

90

邮箱

双因子认证

☐ Open ☒ Close

账号过期天数

30

用户名称

thanos

密码加密摘要算法

将密码和一些随机数字混合加密，增加强度

迭代多次加密，增加强度

密码长度限制

密码

确认密码

天

密码可修改前最短使用期限，默认值0，表示立即生效

天

开启后，第一次登录和密码过期时需要修改密码

天

密码过期时间，默认值90天

邮箱

双因子认证开关

天

账号过期天数，期间未登录账号将不可用

保存

取消

7049_M9A01

版权所有©东方通

6

图 3.1-5：编辑用户

3.1 双因子认证

系统管理员在编辑用户时（如上图），可以对该用户开启“双因子认证”功能，默认为关闭。

1. 选择“Open”后，出现如下图的配置页面。

图 3.1-1：配置双因子认证

2. 单击“使用应用程序设置”后，出现如下二维码页面。

图 3.1-2：输入动态密码开启双因子认证

3. 在手机上下载应用程序“宁盾令牌”，扫描上图中的二维码后，在上图中输入 APP 显示的动态密码（30s 更新一次），并在上图中点击“保存”后，管理控制台将自动跳转回编辑用户页面。

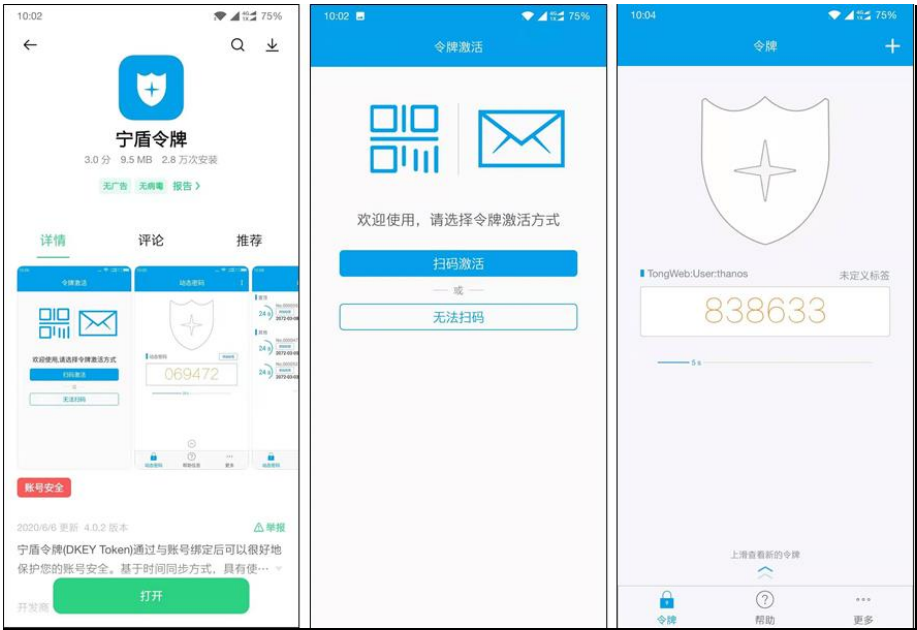


图 3.1-3：宁盾令牌动态密码

开启双因子认证后，该用户用账号及密码登录后管理控制台后，会显示如下双因子认证页面。输入 APP “宁盾令牌” 上的动态密码后，点击“确定”，即可进入管理控制台主页。



图 3.1-4：输入动态密码登录管理控制台

3.2 账号过期

系统管理员在编辑用户时，可以对该用户账号设置过期时间（每次登录后账号的有效期限）。账号过期前7天内，用户每天会收到账号即将失效的邮件提醒。如果用户未在过期前登录，则账号将被冻结。账号冻结后，该用户登录管理控制台时会提示账号过期，如下图所示。



图 3.2-1：账号过期提示

点击**账号找回**后，需要填写正确的账号邮箱地址，否则会收到提示“邮箱与账号维护的邮箱不符”。之后点击“**发送**”，用户将收到“找回账号-验证码”的邮件。在下图中输入邮件中的**验证码**后点击“**提交**”后，可回到登录页面重新登录。

图 3.2-2：账号找回

第4章 用户标识

安全保密管理员拥有的角色权限可以对TongWeb三员用户进行角色的分配、删除用户。默认用户名为security，初始密码为security123.com。

首次登录前需要使用初始密码设置新的密码及邮箱后，使用安全保密管理员的账号及新密码登录管理控制台。安全保密管理员可以进行的操作如下。

4.1 用户管理

1. 单击管理控制台左侧导航树中的“用户管理”后，进入用户管理列表页面。用户列表页面显示已创建的所有三员用户及其他用户，如下图所示。

用户名称	用户所属角色
security	安全保密管理员
auditor	安全审计员
monitor	系统管理员
thanos	系统管理员

图 4.1-1：安全保密管理员用户列表

2. 单击用户名称，进入“编辑用户”，安全保密管理员可给该用户分配角色及设置用户标识级别（安全级别 1-15，级别越高权限越大），如下图所示。

图 4.1-2：安全保密管理员可设置用户标识

图 4.1-3：安全保密管理员可选择用户角色

说明：

角色选择下拉列表可选择无角色、系统管理员、安全保密管理员、安全审计员。更改角色后保存视，会出现如下提示。

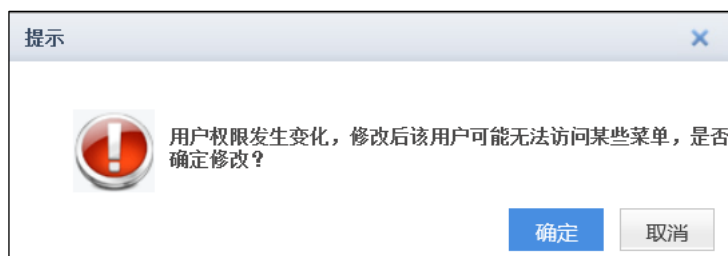


图 4.1-4：变更用户角色后的提示

4.2 用户标识

单击管理控制台左侧导航树中的“用户标识”后，进入安全标记配置列表页面。如下图所示。

安全标记配置

配置系统资源的安全标记

此页用于配置系统资源的安全标记，如访问资源需要的安全级别。

监控概览：

1

启动参数配置：

1

容器配置：

1

会话高可用：

1

访问日志：

1

虚拟主机管理：

1

HTTP通道管理：

1

AJP通道管理：

1

JDBC配置：

1

工作管理器：

1

JMS连接工厂：

1

JMS目的地：

1

无状态会话Bean配置管理：

1

有状态会话Bean配置管理：

1

单例会话Bean配置管理：

1

消息驱动Bean配置管理：

1

应用管理：

1

JCA线程池：

1

JCA连接池：

1

托管对象资源：

1

服务：

1

JNDI-服务器资源域：

1

JNDI-远程EJB域：

1

JNDI-本地EJB源域：

1

JNDI-应用global域：

1

JNDI-应用域：

1

JavaMail配置：

1

监视明细：

1

监视配置：

1

监视回放：

1

监视hung线程：

1

阈值配置：

1

诊断-系统日志：

1

诊断-SQL日志：

1

诊断-访问日志：

1

图 4.2-1：安全标记配置

该页面列出了在管理控制台上可以看到的所有导航栏菜单，安全保密管理员可以对每个导航栏菜单设置不同的标识安全级别（1-15），当“用户标识级别>=导航标识级别”时，说明该用户符合安全标准，可以访问此设置页面。比如安全管理员设置用户admin为系统管理员、标识为12；设置JDBC配置标识为10。那么admin登录管理控制台后可以看到导航栏中的“JDBC配置”。若将admin用户的标识改为9，那么再次登录后在导航栏中则看不到“JDBC配置”了。

第5章 审计日志

TongWeb中安全审计员的功能是查询已经生成的审计日志。安全审计员的默认用户名为**auditor**，初始密码为“auditor123.com”。首次登录前需要使用初始密码设置新的密码及邮箱后，使用安全审计员的账号及新密码登录管理控制台。

安全审计员对审计日志的具体操作可参见《003_TongWeb服务配置指南》“审计日志”章节。

- 开启等保功能后，并开启了审计日志备份（默认目录为\${TongWeb_HOME}/log-bak），备份日志将被加密。
- 开启等保功能后，不得更改审计日志（默认为\${TongWeb_HOME}/logs/audit-log/audit.log），否则安全审计员进行日志查询时，会出现如下错误提示。



图 4.2-1：审计日志被篡改

说明：

集群管理工具的审计日志默认为\${TongWeb_HOME}/logs/heimdall-audit-log/audit.log

附录A 术语及缩略语

名称	说明
TongWeb(简称TW)	东方通应用服务器
\${TongWeb_HOME}	TongWeb的安装路径
TongDataGrid(简称TDG)	东方通会话缓存服务器
TongHttpServer(简称THS)	东方通负载均衡服务器
TongLINK/Q(简称TLQ)	东方通消息中间件

